

ATM Switch Outage and Cash Access Disruption

Improved facilitation-ready version integrating evaluation feedback

Document control	Details
Exercise type	Facilitated tabletop exercise (TTX)
Scenario classification	Internal use only - fictional exercise material
Recommended duration	90 minutes
Primary audience	Executive leadership, crisis management, SOC, technology operations, ATM/payments operations, branch operations, contact center, communications, treasury/liquidity, fraud, legal/compliance
Revision focus	Enhanced realism, cyber accuracy, observable indicators, adversary lifecycle, recovery tradeoffs, cross-functional coordination, formal evaluation criteria, and evidence-backed MITRE ATT&CK mapping
Generated date	13 July 2026

Exercise note

This document preserves the source ATM switch outage scenario and expands it into a more realistic cyber disruption exercise. The added technical evidence is intentionally plausible and internally consistent: participants should not treat it as an assertion about any real bank, processor, vendor, or ATM platform.

Confidential document. For internal distribution and authorized exercise use only. Do not print or transmit externally unless approved by the exercise owner.

Document Sections

- 1. Exercise Overview
- 2. Exercise Objectives
- 3. Scope and Assumptions
- 4. Participant Roles and Coordination Model
- 5. Rules of Engagement
- 6. Scenario Narrative
- 7. What Is the ATM Switch and Cash Access Service?
- 8. Exercise Timeline and Injects
- 9. Decision Points
- 10. Business and Technical Impacts
- 11. Expected Good Practices and Evaluation Criteria
- 12. Debrief Questions
- 13. After-Action Improvement Areas
- 14. Facilitator Quick Reference
- 15. Source Traceability and Improvement Integration
- 16. MITRE ATT&CK Mapping

How to use this exercise

- Facilitator reads each inject aloud and gives participants time to respond using their real roles, procedures, and escalation paths.
- Participants should distinguish known facts, assumptions, and decisions. The scribe should maintain a decision log and action tracker.
- Technical evidence is intentionally introduced gradually so the group must decide when an outage becomes a suspected cyber incident.
- Facilitator notes are not intended to be read verbatim to participants unless needed to steer the discussion.

1. Exercise Overview

Exercise title: ATM Switch Outage and Cash Access Disruption

Exercise type: Facilitated tabletop exercise (TTX)

Audience: Executive, operational, technical, communications, customer operations, fraud, branch operations, treasury/liquidity, legal/compliance, third-party/vendor management

Recommended duration: 90 minutes

Scenario classification: Internal use only

Purpose

This tabletop exercise prepares participants to respond to a disruptive cyber incident affecting ATM transaction routing and customer cash access during a high-demand holiday weekend. The scenario tests how the organization coordinates crisis management, technical triage, processor/vendor coordination, customer remediation, public communications, liquidity support, and evidence-based recovery governance.

Scenario basis

- A retail bank in the financial-services sector operates a national ATM fleet and depends on an ATM switch for transaction routing, authorization, monitoring, and partner network connectivity.
- Critical services include ATM transaction switching, authorization routing, message normalization, reversal/advice handling, availability monitoring, HSM-backed PIN validation interfaces, and processor connectivity.
- The incident begins as a national spike in failed withdrawals with duplicate debit holds, branch overflow, call-center surge, and social-media rumors.
- The exercise now includes environmental detail and observable evidence before cyber escalation, rather than moving directly from unexplained outage to cyberattack.
- The exercise includes an explicit adversary lifecycle with detection opportunities, containment actions, recovery criteria, and evidence-backed ATT&CK mapping.

Revision priorities integrated

Improvement area	How it is addressed
Realism	Added architecture, vendor dependencies, transaction flows, monitoring signals, operating constraints, branch/call-center surge, and holiday staffing pressures.
Coherence	Clarified the causal chain from service outage to suspected cyber event through progressive evidence: anomalous service-account use, unauthorized switch routing changes, health-check suppression, and processor mismatch.
Cyber accuracy	Defined a full adversary lifecycle from initial access through impact and recovery; replaced speculative ATT&CK references with mappings tied to exercise artifacts.
Training value	Added forensic artifacts, SIEM/EDR clues, transaction integrity questions, duplicate debit hold mechanism, and technical recovery tradeoffs.
Structure	Added formal coordination mechanisms, escalation triggers, and evaluation criteria while preserving the original TTX flow.

2. Exercise Objectives

By the end of the exercise, participants should be able to:

- Assess and coordinate the initial response to a suspected cyber-related outage affecting ATM availability at national scale.
- Develop a common operating picture that combines customer impact, ATM transaction telemetry, processor/vendor status, branch/call-center conditions, fraud signals, and cyber evidence.
- Prioritize customer impact management, including cash access alternatives, emergency withdrawal limits, fee remediation, duplicate hold reversal, branch support, and call-center surge handling.
- Evaluate crisis governance, escalation thresholds, and executive decision-making during a holiday-period disruption with incomplete information.
- Test internal and external communications, including customer notifications, media posture, processor coordination, sector coordination, law-enforcement considerations, and regulator engagement.
- Validate technical containment and recovery decision-making for ATM switch services, including evidence preservation, credential revocation, configuration integrity, staged restoration, transaction reconciliation, and enhanced monitoring.
- Challenge technical responders and threat hunters with concrete artifacts, including service-account anomalies, configuration checksum changes, PowerShell execution, scheduled task creation, health-check suppression, and switch timeout patterns.
- Identify gaps in business continuity, liquidity management, operational resilience, third-party coordination, and cyber incident playbooks.

Audience-specific emphasis

Audience	Primary training focus
Executive / Crisis leadership	Set severity, approve public posture, balance restoration speed with safety, authorize cash access/remediation policies, and ensure regulatory/board reporting.
Operational / Business teams	Manage customer harm, branch overflow, call-center scripts, emergency cash support, reconciliation, fee reversal, fraud monitoring, and processor/vendor coordination.
Technical / Cyber teams	Triage telemetry, distinguish outage from cyber cause, preserve evidence, contain compromised access, validate clean configurations, rebuild/reconnect safely, and define recovery gates.

3. Scope and Assumptions

In scope

- ATM withdrawals, balance inquiries, transaction routing, authorization response handling, reversal/advice processing, and availability monitoring.
- Owned ATM fleet, partner ATM channels, processor connectivity, ATM switch cluster, routing rules, service accounts, monitoring agents, and dependent payment services.
- Branch customer overflow, exception handling, cash replenishment, and staff safety.
- Contact center escalation, customer complaint management, social media monitoring, and customer remediation.
- Treasury and liquidity considerations for emergency cash support and high-demand weekend operations.
- Internal and external communications with customers, media, regulators, payment partners, processors, sector coordination groups, and law enforcement as appropriate.
- Technical containment, investigation, evidence preservation, recovery governance, and post-incident reporting.

Out of scope

- Detailed malware reverse engineering or development of exploit code.
- Full jurisdiction-by-jurisdiction legal determination of breach notification obligations.
- Vendor contract negotiation specifics.
- Actual production failover or live system changes during the exercise.
- Attribution to a real threat actor unless participants explicitly identify evidence supporting a hypothesis.

Assumptions

- The organization is a retail bank with nationwide ATM dependency and elevated customer cash demand during a holiday weekend.
- The ATM switch is internally managed but depends on an external processor and partner ATM network connectivity.
- Core banking and card management remain available, but ATM transaction state and reversal handling are impaired.
- Initial information is incomplete. Participants should separate facts, assumptions, hypotheses, and decisions.
- No confirmed customer account compromise or data exfiltration exists at exercise start.
- Participants should answer according to existing roles, responsibilities, operating procedures, and escalation playbooks.

4. Participant Roles and Coordination Model

The exercise separates command ownership from technical decision authority. The Crisis Cell owns enterprise risk decisions; the SOC Incident Commander owns cyber investigation and containment; Technology Operations owns service restoration; business teams own customer harm reduction and operational continuity.

Role / cell	Primary responsibilities during exercise
Crisis Management Lead	Activate crisis governance, chair cross-functional calls, maintain decision log, approve enterprise priorities, and align executive updates.
Executive Sponsor / Business Leadership	Set risk appetite, approve emergency cash support/remediation policies, make public trust decisions, and brief board or senior management.
SOC / Cyber Incident Commander	Classify cyber severity, preserve evidence, coordinate threat hunting, direct containment, validate eradication, and advise on reconnection risk.
Technology Incident Commander	Run ATM switch incident bridge, coordinate infrastructure/application teams, assess recovery paths, manage change freeze, and execute approved restoration.
ATM / Payments Operations	Assess failed transactions, reconcile duplicate holds, coordinate processor/partner network updates, prioritize transaction integrity, and define manual workarounds.
Branch Operations	Implement customer queue management, emergency withdrawal procedures, branch cash controls, staff safety guidance, and escalations for vulnerable customers.
Contact Center / Customer Operations	Deploy scripts, triage complaints, capture duplicate hold cases, monitor wait times, and coordinate customer callbacks.
Treasury / Liquidity	Assess cash demand, cash logistics, emergency supply, branch replenishment, and cash rationing thresholds.
Fraud Operations	Enhance fraud monitoring around failed/retried transactions, unusual withdrawals, social engineering, mule activity, and account takeover attempts.
Legal / Compliance / Privacy	Advise on regulator notification, customer harm, public statements, privilege, evidence preservation, and breach/data impact analysis.
Communications / Media Relations	Develop customer-facing updates, media holding lines, internal talking points, and rumor management cadence.
Third-Party / Vendor Management	Coordinate processor/vendor status, support obligations, contractual escalation, and dependency risk tracking.

Escalation and decision authority

Escalation trigger	Required action	Decision owner
National failed ATM transactions exceed 20% for more than 15 minutes or affect three or more regions.	Open P1 technology incident; notify ATM/payments operations, contact center, branch operations, and technology leadership.	Technology Incident Commander
Unauthorized switch configuration change, anomalous privileged service-account use, unexplained health-check suppression, or suspicious execution on ATM admin host.	Declare suspected cyber-related service disruption; activate SOC Incident Commander; preserve evidence; consider containment before restoration.	SOC Incident Commander
Customer impact exceeds 60 minutes, media interest emerges, regulator inquiry received, or branch/call-center surge creates operational risk.	Activate Crisis Cell and executive reporting cadence; approve customer, liquidity, and communications decisions.	Crisis Management Lead
Recovery requires reconnection of previously isolated switch components or processor links.	Apply recovery gate: evidence reviewed, malicious access removed, known-good configs validated, transaction integrity tests passed, monitoring active.	Joint approval: SOC IC + Technology IC + Business Owner

5. Rules of Engagement

- This is a no-fault learning exercise. The objective is to identify opportunities for improvement, not to evaluate individuals.
- Real incidents take precedence over the exercise. Participants who need to leave should notify the facilitator or exercise lead.
- There are no perfect answers. Participants should discuss tradeoffs, assumptions, and decision rationale.
- Suspend disbelief. The scenario is fictional, but participants should respond as if the events are real.
- Do not fight the scenario. Ask clarifying questions, but continue making decisions under uncertainty.
- Use actual organizational roles, procedures, communication channels, approval paths, and escalation thresholds wherever possible.
- The facilitator may inject new information to test adaptability. New facts supersede earlier assumptions.
- The scribe should record decisions, action owners, open questions, evidence requested, and after-action improvement items.

6. Scenario Narrative

At the start of a long holiday weekend, customers across multiple regions begin reporting failed ATM withdrawals. Some customers also report duplicate debit holds after unsuccessful transactions. Social media complaints rise rapidly, and branches see increased walk-in traffic as customers seek access to cash and account confirmation.

The bank's ATM switch and cash access services are central to transaction routing, authorization, reversal handling, and service availability monitoring. Core banking remains reachable, but ATM authorization traffic is unstable. Early evidence looks like a technology outage: increased timeouts, failed transaction routing, and processor communication errors. As additional evidence emerges, the incident is escalated to suspected cyber-related disruption because switch routing configuration changed outside the approved change window, a privileged service account is used from an unusual jump host, and monitoring agents for selected switch nodes were stopped shortly before the customer impact began.

For the exercise, the working cyber hypothesis is that an adversary exploited an exposed ATM switch administration gateway or remote-support component, used a privileged service account to modify routing logic, and intentionally degraded transaction state handling. The objective is disruption of cash access and erosion of public trust, not confirmed theft of customer funds. The duplicate debit holds are caused by transaction-state inconsistency: authorization holds are created upstream, but the ATM channel times out before receiving a valid response and reversal messages are delayed, malformed, or not accepted for affected transactions.

As the incident develops, the bank faces parallel pressures: restoring essential services safely, preserving evidence, protecting customer trust, coordinating with processors and partners, managing branch and call-center surge, handling duplicate holds and fee remediation, maintaining cash logistics, and preparing regulator-ready reporting.

Adversary lifecycle summary for facilitators

Phase	Exercise behavior	Evidence introduced	Detection opportunity	Containment / recovery focus
Initial access	Adversary exploits a vulnerable internet-facing admin gateway or remote-support component connected to the ATM switch support zone.	WAF/API logs show unusual requests and 5xx errors from a foreign VPS shortly before the outage.	External attack surface monitoring, WAF alerts, abnormal admin API errors.	Block source infrastructure, disable exposed admin path, preserve gateway logs.
Credential abuse	Privileged service account svc-atm-route is used outside normal schedule and from a non-standard jump host.	Identity logs show atypical source, impossible change window, and service-account API calls.	UEBA/SIEM alert on service account anomaly; privileged access management review.	Revoke/rotate credentials, invalidate sessions, check group memberships.
Discovery and movement	Adversary enumerates switch nodes, processor connector services, and configuration repositories.	Sequential connection attempts from jump host to ATM switch subnets and admin ports.	Network service discovery alerts; jump host command telemetry.	Isolate jump host, restrict admin network paths, review lateral movement.
Execution and persistence	Scripted routing-rule update is executed and a scheduled task/service is created to reapply changes.	PowerShell and task scheduler logs show route_update.ps1 and ATMHealthMonitor task creation.	EDR alerts on script execution and task creation outside deployment window.	Quarantine admin host, remove task/service, rebuild from known-good baseline.
Impact	Routing normalization and reversal handling are degraded, causing timeouts, failed withdrawals, and duplicate holds.	Switch telemetry shows timeout spikes, abnormal routing checksums, failed reversal/advice processing, and processor mismatch.	Transaction monitoring, synthetic ATM checks, processor reconciliation alerts.	Restore known-good config, validate idempotency/reversal logic, stage reconnection, monitor integrity.

7. What Is the ATM Switch and Cash Access Service?

The ATM switch and cash access environment is the service layer responsible for routing ATM transactions to the correct authorization path, validating and processing withdrawal and balance requests, supporting availability monitoring, coordinating with processors and dependent banking services, and enabling nationwide cash access through owned and partner ATM channels.

Simplified dependency map

Component	Role in scenario	Failure / compromise concern
ATM terminal fleet	Customer-facing withdrawal and balance inquiry channel.	Displays failed withdrawal even when upstream hold may have been created.
ATM network gateway	Receives terminal messages and forwards them to the switch.	Timeouts, retries, and message normalization errors can multiply customer impact.
ATM switch cluster	Routes ISO 8583-style authorization, advice, and reversal messages to internal or processor paths.	Unauthorized routing changes can create national failure patterns.
Authorization / card host	Approves or declines transactions and places temporary holds.	Can create memo holds even if the ATM channel times out before customer receives cash.
Core banking / ledger	Maintains account balances and final posting.	Core balance may remain accurate while temporary holds distort available balance.
External processor / partner network	Supports partner ATM routing and settlement dependencies.	Processor stability helps determine whether outage is internal, external, or shared.
HSM / PIN validation services	Supports secure PIN validation and cryptographic operations.	Availability must be verified before service restoration; no HSM compromise is assumed.
Monitoring / SIEM / EDR	Provides operational and cyber telemetry.	Health-check suppression or logging gaps are early cyber indicators.

Normal withdrawal transaction flow

- Customer initiates withdrawal at an ATM terminal.
- ATM sends authorization request through the ATM network gateway to the ATM switch.
- The switch normalizes the message and routes it to the bank authorization host or external processor path.
- Authorization host validates account/card status and creates a temporary debit hold if funds are available.
- ATM switch returns approval/decline to terminal; terminal dispenses cash only if a valid approval is received.
- If the transaction fails after hold creation, a reversal/advice message should release or correct the temporary hold.
- Reconciliation processes compare ATM journal, switch logs, processor files, and core account activity.

Mechanism for duplicate debit holds in this exercise

Duplicate debit holds are not assumed to be stolen funds. The exercise mechanism is a transaction-state failure: the authorization host creates a temporary hold, but the manipulated switch routing logic causes a timeout before the ATM receives a valid response. The terminal displays a failed transaction and the customer retries. Because the routing manipulation changes or strips a correlation field used for idempotency, the retry is treated as a separate authorization and creates an additional temporary hold. Reversal messages for the original timed-out requests are delayed or rejected due to malformed routing metadata. The recovery process must therefore include transaction integrity validation, hold release, fee reversal, customer remediation, and fraud monitoring.

8. Exercise Timeline and Injects

The timeline preserves the original four-inject structure while adding progressive evidence. Facilitators may adjust times to match local operations. The scenario uses local time for the bank's primary operations center.

Inject 1 - National spike in failed withdrawals

Simulated time: Friday, 08:00

Elapsed time: Incident discovery

Inject

Customers across multiple regions report failed ATM withdrawals and duplicate debit holds, while branch call volumes surge. Internal monitoring shows a sharp increase in ATM authorization failures, repeated timeout conditions in the ATM switch service, and a rising number of reversal/advice messages awaiting processing.

What participants know

- ATM failures are occurring nationally, not in a single region.
- Owned ATMs and some partner ATM transactions are affected; card-not-present and digital banking channels are not showing the same failure pattern.
- Some transactions appear unsuccessful to customers but still create temporary debit holds.
- Branches are beginning to receive overflow traffic and account-balance inquiries.
- The external processor has not declared a global outage at this stage.
- The root cause is not confirmed; the event starts as a major technology/service incident.

Technical evidence / artifacts available if requested

- ATM switch dashboard: authorization timeout rate increased from 2% baseline to 31% across three regions between 07:52 and 08:07.
- Processor connector logs: increased response-time variance, but processor status page remains green.
- Core banking logs: temporary memo holds are being created for some requests that later appear as terminal failures.
- Switch reversal queue: backlog of reversal/advice messages increased 4x compared with normal Friday morning volume.
- Change calendar: no approved production change for the ATM switch during the prior 12 hours.

Discussion questions

- How is the incident initially classified and who owns command at this stage?
- What threshold triggers Crisis Cell activation versus technology incident management only?
- What immediate actions are taken to verify scope, customer impact, processor dependency status, and transaction integrity?
- Which customer-facing channels need rapid updates first?
- How will the bank handle duplicate holds, customer complaints, and potential fee remediation from the outset?
- What branch, contact center, treasury, and fraud surge actions are needed?

Expected actions

- Open and triage a high-severity technology incident; appoint a Technology Incident Commander.
- Create a common operating picture covering ATM failure rate, regions, transaction types, processor status, branch traffic, call volumes, and customer complaints.

- Notify SOC duty lead that cyber involvement is not confirmed but telemetry should be reviewed.
- Freeze non-essential ATM switch changes and preserve relevant logs.
- Coordinate with processor/vendor support and request transaction-level samples.
- Prepare customer service guidance for failed withdrawals, duplicate holds, and expected remediation.
- Establish a decision log and issue the first internal situation update.

Facilitator notes

Push participants to avoid premature attribution. The correct behavior is to manage a major service outage while preserving evidence and asking cyber-relevant questions. Challenge whether duplicate holds and branch overflow are already covered by operational playbooks.

Evaluation markers

- Participants identify an incident commander and decision log within the first discussion cycle.
- Participants request transaction samples and processor evidence rather than relying on status-page assumptions.
- Participants define customer-impact actions before root cause is known.
- Participants preserve logs and freeze changes without declaring cyber prematurely.

Inject 2 - Observable indicators, public trust, and cash access decisions

Simulated time: Friday, 10:30

Elapsed time: 2.5 hours after discovery

Inject

Public complaints accelerate online. Rumors claim the bank is under cyberattack and that customer balances are at risk. Media inquiries ask whether the outage is cyber-related. At the same time, technology teams identify unauthorized ATM switch routing configuration changes and anomalous privileged service-account activity. Restoration timing remains uncertain.

What participants know

- Call-center wait times are rising sharply and branches report elevated demand for over-the-counter withdrawals.
- The processor reports no matching widespread outage on its side and asks the bank to validate internal routing rules.
- An unauthorized routing configuration checksum change occurred at 07:44, outside the approved change window.
- The service account svc-atm-route authenticated from a jump host not normally used for ATM switch administration.
- No evidence of customer data exfiltration or core ledger manipulation has been identified.
- The event is now a suspected cyber-related service disruption.

Technical evidence / artifacts available if requested

- Identity logs: svc-atm-route successful authentication at 07:38 from JH-OPS-17; prior baseline shows use only from deployment automation host DEPLOY-ATM-02.
- Admin API logs: routing rule update POST /switch/routing/rules committed at 07:44; change ticket field blank.
- SIEM alert: service account interactive session plus configuration update outside maintenance window.
- Network logs: abnormal requests to ATM admin gateway from an external VPS at 07:21-07:30, followed by gateway 5xx errors.
- Transaction samples: affected messages show mismatched correlation fields between authorization request, timeout record, and reversal/advice.

Discussion questions

- Who has authority to declare this a suspected cyber incident and what changes in governance?
- Does the SOC direct containment, or does the Crisis Cell direct technical isolation? How are these responsibilities separated?
- Should the bank disable the suspicious service account or isolate the switch administration path immediately, and what operational risk does that create?
- Who decides whether to enable emergency cash support and under what limits?
- How should the bank prioritize vulnerable customers, cash availability, and branch safety?
- What should the first public statement say, and what should it avoid saying?
- When do regulators, payment partners, law enforcement, or sector coordination groups need notification?

Expected actions

- Activate cyber incident governance with SOC Incident Commander and maintain Technology Incident Commander for service restoration.
- Disable or rotate the suspicious service account after preserving evidence and identifying operational dependencies.
- Isolate or restrict ATM switch administration paths while keeping customer transaction paths under controlled monitoring if safe.
- Stand up cross-functional crisis management covering SOC, technology, ATM/payments, branch, contact center, treasury, legal/compliance, fraud, communications, and vendor management.
- Define emergency cash-access thresholds, branch exception authority, and fee/hold remediation principles.
- Issue clear customer messaging: acknowledge service disruption, explain that available balances may be affected by temporary holds, avoid unsupported cyber claims, and commit to updates.
- Prepare regulator notification decision points and evidence package.

Facilitator notes

This inject justifies the transition from outage to suspected cyber incident. Push for precise governance: the SOC recommends and executes cyber containment; the Crisis Cell makes enterprise-risk decisions such as public communications, customer remediation, liquidity support, and regulator engagement.

Evaluation markers

- Participants distinguish technical containment authority from enterprise crisis authority.
- Participants base cyber escalation on concrete evidence, not online rumor.
- Participants decide customer remediation and communications principles despite incomplete root cause.
- Participants identify transaction-integrity and duplicate-hold mechanisms.

Inject 3 - Cyber suspicion intensifies and service restoration is delayed

Simulated time: Friday, 14:00

Elapsed time: 6 hours after discovery

Inject

Cyber operations identify artifacts consistent with targeted disruption of transaction routing logic and supporting service dependencies. There is still no evidence of customer account compromise or confirmed data exfiltration, but restoration requires staged recovery. Branches report rising confrontational customer interactions, and the contact center is exceeding service-level targets.

What participants know

- The event is formally treated as a cyber-related service disruption.
- The suspected malicious changes affected routing normalization and reversal handling for a subset of transaction paths.
- No evidence indicates that customer balances were altered in the core ledger; the visible customer impact is failed transactions and temporary holds.
- Recovery may require rebuilding switch configuration from known-good baseline and validating transaction integrity before reconnection.
- Customer frustration is creating reputational, safety, and conduct risk at some sites.
- Emergency cash demand is higher than forecast for the holiday weekend.

Technical evidence / artifacts available if requested

- EDR telemetry: PowerShell launched route_update.ps1 from the ATM admin host at 07:42 using the svc-atm-route context.
- Task scheduler logs: new scheduled task ATMHealthMonitor created at 07:46 to reapply routing configuration every 20 minutes.
- Monitoring logs: health-check agent for two switch nodes stopped at 07:49, creating partial visibility loss.
- Configuration repository: production switch routing file checksum differs from the last approved deployment baseline.
- Threat hunting: no confirmed data staging, bulk file transfer, or outbound exfiltration from ATM switch servers.
- Reversal processing: queue contains duplicate or mismatched STAN/RRN fields requiring controlled reconciliation.

Discussion questions

- What technical containment decisions are appropriate before recovery is attempted?
- What evidence is needed before reconnecting or restoring ATM switch functions?
- How should the bank message the difference between service disruption, temporary holds, and account compromise?
- What fraud, safety, and conduct risks are increasing as the outage continues?
- Which workarounds remain viable if the outage extends through the weekend?
- How will the bank balance emergency cash access with fraud controls and cash logistics constraints?
- What are the go/no-go criteria for restoring service if some forensic work is incomplete?

Expected actions

- Contain the admin host and remove persistence mechanisms from the restoration path.
- Revoke/rotate compromised credentials and validate privileged group memberships.
- Rebuild or restore ATM switch configuration from a known-good baseline rather than manually editing the affected production file.
- Implement enhanced fraud monitoring for repeated withdrawals, account takeover attempts, and social engineering related to the outage.
- Coordinate branch safety support, emergency cash controls, and customer escalation scripts.
- Define minimum viable restoration, staged reconnect sequence, test transactions, rollback criteria, and executive approval gates.
- Update internal and external messaging with plain-language explanations and a consistent update cadence.

Facilitator notes

Focus the conversation on risk tradeoffs: restoring quickly versus restoring safely, preserving evidence versus reducing customer harm, and supporting cash access while managing fraud and liquidity. Encourage technical participants to translate recovery prerequisites into business-language decision criteria.

Evaluation markers

- Participants define measurable recovery gates rather than relying on 'SOC says it is resolved'.
- Participants address both technical containment and customer/branch safety impacts.
- Participants include fraud and treasury in decisions about emergency cash.
- Participants avoid unsupported claims that customer funds are stolen or balances are compromised.

Inject 4 - Controlled restoration, backlog management, and post-incident obligations

Simulated time: Saturday, 09:00

Elapsed time: 25 hours after discovery

Inject

The processor confirms stable connectivity and the bank's cyber and technology teams have removed unauthorized configuration changes from the restoration path. SOC still requires validation checks before full reconnection and normalization. Transaction backlogs, customer complaints, fee reversals, duplicate hold releases, and branch cash replenishment issues remain active. Senior leadership requests a preliminary impact summary and regulator-ready timeline.

What participants know

- Core disruption conditions are improving, but service restoration must be controlled and monitored.
- Known-good routing configurations have been restored in a pre-production validation environment.
- SOC has not identified confirmed data exfiltration, but monitoring will continue.
- Customer remediation and complaint handling will continue after technical restoration.
- A post-incident report will likely be required for internal governance and relevant regulatory authorities.
- Branches and contact center need updated scripts to explain recovery, holds, and remediation timelines.

Technical evidence / artifacts available if requested

- Validation environment: test withdrawals, balance inquiries, reversals, and partner ATM routing pass in controlled test set.
- Credential review: suspicious service account disabled, replacement account created with break-glass approval and short-term monitoring.
- Config review: production routing checksum matches last approved baseline; unauthorized scheduled task removed.
- Monitoring: EDR, SIEM, synthetic ATM checks, processor alerts, and transaction reconciliation dashboards enabled.
- Reconciliation: list of impacted transaction references generated for hold release, fee reversal, and customer communications.
- Regulator pack: timeline, impact metrics, containment decisions, customer remediation plan, and recovery criteria are drafted.

Discussion questions

- Who authorizes reconnection and on what criteria?

- How will the bank validate transaction integrity after restoration?
- What is the plan for backlog processing, duplicate hold release, and customer remediation?
- What communications are needed to close the incident with customers, regulators, and internal stakeholders?
- What lessons learned should be captured immediately while facts are fresh?
- How long should heightened monitoring remain active and who owns closure?

Expected actions

- Execute staged restoration with clear approval gates and rollback criteria.
- Validate transaction integrity across ATM journals, switch logs, processor files, reversal/advice queues, and core holds.
- Release duplicate holds and reverse fees using a documented, auditable remediation process.
- Publish recovery communications and customer remediation steps.
- Prepare executive summary, regulator-ready narrative, board update, and after-action review plan.
- Assign owners and due dates for resilience improvements, including switch configuration integrity, privileged access, monitoring, and holiday surge readiness.

Facilitator notes

Ensure participants recognize that the incident is not over when ATM service returns. Customer trust, reconciliation, fee remediation, branch replenishment, regulator engagement, and control improvements require continued ownership.

Evaluation markers

- Participants require joint SOC, technology, and business approval for reconnection.
 - Participants explicitly validate duplicate holds and reversals, not just service availability.
 - Participants define customer, regulator, and executive closure communications.
 - Participants assign after-action owners and deadlines.
-

9. Decision Points

Facilitators should ensure the group reaches explicit decisions on the following items.

Decision	Key considerations	Suggested owner
Incident severity and escalation level	Scope, customer harm, national impact, duration, transaction integrity, cyber indicators, media/regulator attention.	Technology IC then Crisis Lead/SOC IC as evidence evolves
Crisis management activation	National customer impact, holiday timing, branch/call center surge, reputational risk, liquidity pressure.	Crisis Management Lead
Cyber incident declaration	Unauthorized config change, privileged account anomaly, suspicious execution/persistence, health-check suppression.	SOC Incident Commander
Containment actions	Disable service account, isolate admin gateway/jump host, freeze changes, preserve evidence, maintain customer transaction continuity if safe.	SOC IC with Technology IC
Emergency cash access	Customer hardship, vulnerable customers, cash availability, branch safety, fraud controls, transaction limits.	Executive Sponsor / Branch Ops / Treasury
Customer remediation	Duplicate holds, fee waivers, overdraft impact, complaint handling, proactive customer outreach.	Customer Ops / Payments Ops / Legal
Public communications	Accuracy, empathy, cyber uncertainty, balance-safety wording, update cadence, approval path.	Communications with Legal and Crisis Lead
Regulator engagement	Notification thresholds, jurisdiction, operational resilience impact, cyber classification, preliminary impact report.	Legal / Compliance
Recovery and reconnection	Known-good config, eradication, credential reset, monitoring, transaction validation, rollback criteria.	Joint SOC IC + Technology IC + Business Owner
Closure and after-action	Customer remediation completion, monitoring period, regulator commitments, lessons learned, control improvements.	Crisis Lead / Resilience Owner

10. Business and Technical Impacts

Impact category	Scenario effects	Evidence / metric to request
Customer impact	Customers cannot access cash; some see reduced available balance due to duplicate temporary holds; complaints rise.	Failed withdrawal count, duplicate hold count, customer complaint volume, vulnerable-customer cases.
Branch operations	Branch congestion, staff stress, elevated safety risk, manual exception handling, cash replenishment pressure.	Queue time, branch footfall, cash inventory, security incidents, emergency withdrawal approvals.
Contact center	Wait times exceed targets; agents need accurate scripts; social media rumors increase call complexity.	Average speed of answer, abandonment rate, top complaint categories, script update cadence.
Treasury / liquidity	Higher cash demand during holiday weekend; need to balance cash availability with fraud and branch security.	Branch cash positions, replenishment ETA, emergency cash limits, logistics constraints.
Fraud / conduct	Repeated transactions, panic withdrawals, scams exploiting outage, account takeover attempts, fee/hold complaints.	Repeat-withdrawal patterns, suspicious activity alerts, scam reports, fee reversal exceptions.
Technology	ATM switch routing instability, authorization timeouts, reversal backlog, monitoring gaps, admin host compromise indicators.	Error rates, routing checksums, service status, EDR/SIEM alerts, processor response times.
Regulatory / legal	Operational resilience scrutiny, customer treatment obligations, cyber incident reporting assessment, evidence preservation.	Timeline, customer harm, remediation plan, severity rationale, regulator contacts.
Reputation	Visible cash-access outage, media questioning, public rumor, customer trust erosion.	Media inquiries, social sentiment, statement timing, update cadence, customer trust indicators.

Technical recovery tradeoffs

- Fast restore versus safe restore: reconnecting before persistence and credential abuse are resolved may reintroduce the malicious routing state.

- Evidence preservation versus service recovery: imaging and log capture should be prioritized for compromised admin systems, while clean systems may be used for staged restoration.
- Manual fix versus known-good rebuild: manual edits risk missing hidden changes; known-good baseline restoration provides stronger integrity assurance.
- Customer availability versus transaction integrity: service availability should not be declared restored until holds, reversals, and reconciliation are controlled.
- Emergency cash support versus fraud risk: customer hardship support must be paired with limits, identification, monitoring, and exception logging.

11. Expected Good Practices and Evaluation Criteria

Participants should demonstrate the following good practices during the exercise.

- Rapid formation of a common operating picture across business, technology, cyber, and customer impact dimensions.
- Clear crisis ownership, cyber incident command, technology incident command, and decision logging.
- Evidence-based escalation from outage to suspected cyber incident.
- Customer-centric remediation planning, including duplicate hold release, fee reversal, vulnerable-customer support, and branch safety.
- Close coordination across SOC, IT, operations, treasury, fraud, communications, legal/compliance, and vendors.
- Recovery governance that balances speed, safety, evidence preservation, and transaction integrity.
- Early preparation for regulator, executive, and board-level reporting.

Evaluation criteria

Criterion	Strong performance looks like	Observer evidence
Governance and escalation	Participants identify owners, escalation triggers, severity, crisis activation, and decision authority without confusion.	Decision log, named owners, timely escalation, clear SOC/technology/crisis separation.
Technical triage and cyber accuracy	Participants request telemetry, validate hypotheses, preserve evidence, and map cyber indicators to containment actions.	Log requests, artifact review, credential containment, config integrity validation, threat hunting plan.
Customer impact management	Participants prioritize customer harm, branch/call-center load, fee/hold remediation, and vulnerable-customer support.	Customer scripts, remediation principles, emergency cash rules, branch surge actions.
Recovery governance	Participants define measurable go/no-go criteria and staged restoration with rollback and monitoring.	Known-good baseline, test cases, approval gates, integrity checks, monitoring period.
Communications and regulatory	Participants issue accurate, empathetic, legally reviewed communications and identify regulator notification thresholds.	Draft statements, stakeholder map, regulator-ready timeline, media holding line.
Cross-functional coordination	Participants include all relevant teams and avoid single-cell decision-making on enterprise impacts.	Meeting cadence, RACI, action tracker, unresolved decisions, dependency management.

Observer confidence scorecard

After each inject, observers may rate confidence from 1 (not confident) to 5 (fully confident).

Scorecard statement	Relevant injects
We can rapidly identify ownership and escalation thresholds for national ATM disruption.	Injects 1-2
We can distinguish a technology outage from suspected cyber disruption using observable evidence.	Injects 1-3
We can preserve evidence while still progressing operational recovery.	Injects 2-4
We can explain duplicate debit holds and manage customer remediation.	Injects 1-4
We can execute emergency cash support without losing fraud and liquidity control.	Injects 2-3

Scorecard statement	Relevant injects
We can define safe reconnection criteria for ATM switch services.	Injects 3-4
We can prepare a regulator-ready timeline and after-action plan.	Inject 4

12. Debrief Questions

General debrief

- What worked well in the first 60 minutes of the scenario?
- Where did roles, responsibilities, or escalation thresholds appear unclear?
- Did the group create and maintain a common operating picture with both technical and customer impact data?
- What evidence justified the transition from service outage to suspected cyber incident?
- Did restoration governance appropriately balance speed and safety?
- What capabilities, playbooks, or partner arrangements should be improved before the next exercise?

Executive and crisis leadership

- Were executive decisions made with sufficient facts and clearly documented assumptions?
- Were public trust, customer harm, and regulatory considerations balanced against technical uncertainty?
- Were emergency cash support and fee remediation decisions timely and customer-centric?
- Were board/regulator updates credible, concise, and grounded in evidence?

Operational and customer teams

- Were branch and contact center teams given practical scripts and escalation paths?
- Were duplicate holds, fee reversals, complaints, and vulnerable-customer cases handled consistently?
- Were cash logistics and branch safety escalated at the right time?
- Did fraud monitoring adapt to repeated failed/retried transactions and scam risk?

Technical and cyber teams

- Which technical indicators were most important for cyber escalation?
- Were logs, images, configuration baselines, and transaction samples preserved early enough?
- Were the containment actions sequenced correctly to avoid unnecessary customer harm?
- Were recovery gates specific enough to support safe reconnection and transaction integrity validation?
- What detection use cases should be added or tuned for future ATM switch incidents?

13. After-Action Improvement Areas

Potential improvement themes include:

Theme	Potential improvement actions
ATM outage and cash-access playbooks	Define P1 escalation, national outage operating model, branch surge actions, emergency withdrawal criteria, and customer scripting.
Duplicate hold and fee remediation	Document ownership, reconciliation logic, customer notification, hold-release SLA, fee/overdraft reversal, and complaint tracking.
Switch configuration integrity	Baseline routing configurations, monitor checksum drift, enforce change-ticket validation, add dual approval for routing changes.
Privileged access management	Restrict service-account interactive use, rotate credentials, enforce just-in-time admin access, monitor anomalous service-account behavior.

Theme	Potential improvement actions
Monitoring and detection	Add synthetic ATM transactions, reversal queue thresholds, processor mismatch alerts, admin API anomaly alerts, and health-check suppression alarms.
Processor and third-party coordination	Define escalation contacts, evidence exchange, status cadence, transaction sample exchange, and joint recovery testing.
Recovery validation	Create known-good rebuild procedures, go/no-go checklists, test cases for withdrawals/balance/reversals, and rollback criteria.
Branch and contact center resilience	Prepare surge staffing, safety escalation, customer scripts, vulnerable-customer protocols, and holiday coverage models.
Regulatory reporting	Maintain notification matrix, regulator-ready timeline template, impact metrics, remediation tracking, and post-incident report owner.
Exercise program	Repeat with a longer outage variant, processor outage variant, insider change variant, and data compromise variant.

14. Facilitator Quick Reference

Suggested pace

Segment	Recommended duration
Introduction, objectives, and rules	10 minutes
Inject 1 - National failed withdrawals	15 minutes
Inject 2 - Observable indicators and public trust	20 minutes
Inject 3 - Cyber suspicion and delayed restoration	20 minutes
Inject 4 - Controlled restoration and post-incident obligations	15 minutes
Final debrief and lessons learned	10 minutes

Optional artifacts facilitators may provide

- Mock customer complaints and social media posts.
- Branch queue and call-center volume dashboard.
- ATM switch availability dashboard showing authorization timeout rates.
- Processor status email and transaction sample request.
- SIEM alert for anomalous service-account activity.
- EDR alert for PowerShell execution and scheduled task creation.
- ATM switch routing checksum comparison report.
- Draft media holding statement for participant review.
- Regulator inquiry email requesting timeline and customer impact estimate.
- Executive situation report template and decision log.

Sample facilitator prompts

- What do you know, what do you assume, and what evidence do you need next?
- Who owns this decision and who must be consulted before it is final?
- What would you tell customers now, in plain language, without over-claiming?
- What would make restoration unsafe even if the processor says connectivity is stable?

- How do you know duplicate holds are temporary and how will you prove they were resolved?
- What will regulators ask for in the first written timeline?

Glossary

Term	Meaning
ATM switch	Transaction-routing service that receives ATM requests and routes them to authorization, processor, or partner network paths.
Authorization request	Message asking whether a transaction should be approved, declined, or referred.
Debit hold / memo hold	Temporary reduction of available balance created during authorization before final posting or reversal.
Reversal / advice	Message used to correct or release transaction state when a transaction fails after an authorization step.
STAN / RRN	Transaction identifiers used to correlate ATM, switch, processor, and core-banking records.
HSM	Hardware Security Module supporting cryptographic operations such as PIN validation.
SOC	Security Operations Center responsible for cyber triage, containment guidance, and threat hunting.
SIEM / EDR	Security monitoring technologies that collect logs and endpoint telemetry for detection and investigation.
P1 / Sev 2	Example severity labels: P1 for major technology incident, Sev 2 for significant cyber incident requiring coordinated response.
Common operating picture	Shared, current view of facts, impacts, decisions, owners, risks, and next actions.

15. Source Traceability and Improvement Integration

This tabletop exercise was generated from the uploaded ATM switch outage exercise and revised using the uploaded evaluation feedback. The revised design preserves the original scenario intent while addressing concrete improvement areas identified in the evaluation.

Source / feedback item	Integration in revised exercise
Original ATM switch disruption scenario	Preserved national failed withdrawals, duplicate debit holds, branch overflow, public rumors, emergency cash support, fee remediation, processor coordination, and staged restoration.
Need for environmental detail	Added architecture, dependency map, transaction flow, monitoring signals, vendor/processor dependencies, cash logistics, and holiday operating constraints.
Need for clearer outage-to-cyber transition	Added progressive evidence before cyber escalation: unauthorized routing checksum change, anomalous service-account login, admin API events, processor mismatch, and monitoring suppression.
Need for complete adversary lifecycle	Added lifecycle phases with initial access, credential abuse, discovery/movement, execution/persistence, impact, detection, containment, and recovery.
Need for technical evidence and recovery tradeoffs	Added SIEM/EDR artifacts, config baseline checks, reversal queue details, forensic preservation, credential rotation, staged restoration, and transaction integrity validation.
Need to explain duplicate debit holds	Defined transaction-state failure mechanism involving temporary holds, timeout handling, idempotency/correlation mismatch, and delayed/malformed reversals.
Need for coordination mechanisms	Added command ownership, escalation triggers, decision owners, joint reconnection approval, and observer criteria.
Need for evaluation criteria	Added observer scorecard and performance criteria aligned to governance, technical triage, customer impact, recovery, communications, and coordination.

Assumptions added for realism are fictional and intended solely to improve exercise quality. They should be replaced with organization-specific architecture, severity labels, transaction flows, thresholds, and regulatory notification requirements before live delivery.

16. MITRE ATT&CK Mapping

The mapping below is evidence-based within the exercise. Each technique is tied to explicit scenario behavior and observable artifacts introduced during the injects. Mappings should be refined after the exercise if participants add organization-specific evidence, tooling, or architecture details.

Lifecycle stage	Scenario behavior / artifact	ATT&CK tactic	Technique mapping	Evidence strength
Initial access	Unusual requests and 5xx errors against the ATM administration gateway shortly before impact; suspected exploitation of exposed admin/remote-support component.	Initial Access	T1190 - Exploit Public-Facing Application	Introduced as scenario evidence in Inject 2; validate with WAF/API/gateway logs.
Credential abuse	svc-atm-route used from non-standard jump host and outside maintenance window to commit routing changes.	Initial Access / Persistence / Privilege Escalation / Defense Evasion	T1078.002 - Valid Accounts: Domain Accounts	Introduced as identity log evidence in Inject 2.
Privilege / access manipulation	Temporary admin group permission or access path change enabling routing-rule update.	Persistence / Privilege Escalation	T1098.007 - Account Manipulation: Additional Local or Domain Groups	Facilitator evidence if participants request privileged-access review.
Discovery	Sequential connection attempts from jump host to switch nodes, processor connectors, and admin ports.	Discovery	T1046 - Network Service Discovery	Introduced as network telemetry in lifecycle summary and Inject 3.
Lateral movement	Remote administrative connection from jump host to ATM switch administration node.	Lateral Movement	T1021.006 - Remote Services: Windows Remote Management	Exercise evidence if endpoint/network telemetry is requested.
Execution	PowerShell executes route_update.ps1 under the compromised service-account context.	Execution	T1059.001 - Command and Scripting Interpreter: PowerShell	EDR artifact in Inject 3.
Persistence	Scheduled task ATMHealthMonitor created to reapply malicious routing configuration.	Persistence / Execution	T1053.005 - Scheduled Task/Job: Scheduled Task	Task scheduler artifact in Inject 3.
Service persistence alternative	If participant architecture uses service-based deployment rather than scheduled tasks, malicious service creation can represent persistence.	Persistence	T1543.003 - Create or Modify System Process: Windows Service	Alternative mapping; use only if service evidence is selected by facilitator.
Defense evasion / visibility loss	Health-check or monitoring agent for switch nodes is stopped, reducing visibility before the outage is fully understood.	Defense Evasion	T1685 - Disable or Modify Tools	Monitoring/EDR artifact in Inject 3.
Impact - service disruption	Routing workers or health checks are stopped/disabled, contributing to authorization timeouts.	Impact	T1489 - Service Stop	Introduced through monitoring and service status evidence.
Impact - availability degradation	Application-level transaction queues and timeout conditions degrade ATM availability nationally.	Impact	T1499.003 - Endpoint Denial of Service: Application Exhaustion Flood	Supported by timeout/queue telemetry; not a volumetric network DDoS.
Impact - transaction integrity disruption	Routing metadata/correlation fields are altered in transit, causing idempotency mismatch, failed reversals, and duplicate temporary holds.	Impact	T1565.002 - Data Manipulation: Transmitted Data Manipulation	Directly tied to duplicate hold mechanism and transaction samples.

Explicit non-mappings and caveats

- Data exfiltration is not mapped because the scenario provides no evidence of bulk staging or outbound theft of customer data.
- Ransomware is not mapped because no encryption, ransom demand, or destructive payload is introduced.

- Network Denial of Service is not the primary mapping because the scenario evidence points to application-level transaction disruption rather than volumetric traffic flooding.
- Attribution is deliberately out of scope. Participants may form hypotheses, but the exercise does not provide enough evidence to attribute the incident to a named actor.

End of exercise package.